

SC EXAM PREP — PREDICTED 2026

セキュリティマネジメント・法規

ISMS／リスク評価／個人情報保護法／サプライチェーン・SBOM。JIS Q 27000の用語定義から改正個人情報法、SBOM／SLSAまで、午前II・午後の双方で狙われる論点を5問で体系学習する。

Q1・JIS Q 27000

リスク対応の定義

頻出 ★★★

Q2・リスク管理

残留リスクの概念

頻出 ★★☆

Q3・改正個人情報法

漏えい報告の義務化

頻出 ★★★

Q4・SBOM

SPDX／CycloneDX

頻出 ★★★

Q5・サプライチェーン

SLSA と完全性確保

頻出 ★★☆

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「管理プロセス」→「法規制」→「サプライチェーン技術」で切り分ける学習動線

Q1

リスク対応

回避・低減・移転・保有の選択肢。特定/分析/評価(アセスメント)と対比する用語問題

JIS Q 27000 / 定義

Q2

残留リスク

対応後に残るリスク。受容にはリスクオーナーの承認。固有/二次リスク・選好と区別

リスク管理 / 承認

Q3

改正個人情報法

漏えい等報告・本人通知の義務化。要配慮個人情報・仮名加工情報・越境移転

個人情報法 / 2022施行

Q4

SBOM

構成部品表。
SPDX/CycloneDXで版数・依存を可視化し脆弱性影響を即特定

サプライチェーン / 部品表

Q5

完全性確保

SLSAで来歴保証、
cosign/Sigstoreで署名検証。typosquatting・推移的依存に注意

SLSA / 来歴

STEP 1 | WHY

ISMSのリスクマネジメント用語と法規制の全体像(なぜ管理・報告が要るか)を理解する

STEP 2 | HOW

5問で「どの用語・どの制度か」を判別し、似た概念のひっかけ選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(一元管理・SBOM整備・要配慮情報の同意・来歴検証)へ落とす

① 基礎概念 — 分野の全体像マップ

「マネジメント／法規制／サプライチェーン」の3層で本デッキ5問を配置

CONCEPT

層 / 領域	プロセス・仕組み	主なキーワード
リスクマネジメント	Q1 リスクアセスメント(特定・分析・評価)→リスク対応(回避/低減/移転/保有)	JIS Q 27000 / PDCA / リスク基準
リスクの状態	Q2 固有リスク→対応→ 残留リスク (リスクオーナー承認)	二次リスク / リスク選好 / 受容
法規制・コンプラ	Q3 改正個人情報保護法(2022全面施行)。漏えい報告・本人通知の義務化	要配慮個人情報 / 仮名加工情報 / 越境移転
サプライチェーン	Q4 SBOM(部品表) / Q5 SLSA・cosignによる完全性確保	SPDX / CycloneDX / 来歴 / 署名検証

核心: この分野は「①組織のリスクをどう回すか(ISMSプロセス・用語)」「②法令上どこまで義務か(個人情報法)」「③外部部品の弱点をどう管理するか(SBOM・SLSA)」の3層で切り分ける。用語の定義取り違えと、制度の適用範囲の勘違いが4択の失点源となる。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「定義・タイミング・対象」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
プロセスの位置	リスク対応：リスクを 修正 するプロセス(回避・低減・移転・保有)	リスクアセスメント： 特定・分析・評価 の3工程。対応の前段
リスクの状態	残留リスク： 対応後 に残るリスク。受容はリスクオーナー承認	固有リスク： 管理策適用前 のリスク／二次リスク=対応策が生む新リスク
加工情報	要配慮個人情報：取得に原則 本人の事前同意 が必要。オプトアウト提供不可	仮名加工情報：原則 第三者提供禁止 (委託・承継・共同利用を除く)
SBOMフォーマット	SPDX：ISO/IEC 5962。ライセンス 管理 に強い	CycloneDX：OWASP発。 脆弱性・サプライチェーンセキュリティ に強い
サプライ攻撃	typosquatting：正規名に 酷似した名称 の悪意パッケージで誤インストール誘発	署名鍵・アカウント侵害：正規の 鍵/アカウント を窃取し改ざん版を公開

リスク対応 Risk Treatment

リスクを修正するプロセス。回避・除去・低減(起こりやすさ/結果の変更)・共有(移転)・保有(受容)の選択肢を選定・実施する。

 **JIS Q 27000:2019****要配慮個人情報**

人種・信条・病歴・健康情報等、不当な差別・偏見が生じ得る記述を含む個人情報。取得に原則本人の事前同意が必要。

 **個人情報保護法****SBOM 部品表**

ソフトウェアの構成部品(名称・版数・依存関係)を機械可読に一覧化。脆弱性公表時の影響範囲特定を迅速化。

 **SPDX / CycloneDX****cosign / Sigstore**

配布物・コンテナイメージ等への電子署名と検証を行う仕組み。成果物の真正性・完全性を担保する。

 **署名・検証****残留リスク Residual Risk**

リスク対応後になお残るリスク。その受容にはリスクオーナー(リスク所有者)の承認が必要。

 **リスク管理****仮名加工情報**

他情報と照合しない限り特定個人を識別できないよう加工した情報。原則、第三者提供は禁止。

 **個人情報保護法****SLSA**

Supply-chain Levels for Software Artifacts。ビルドの改ざん耐性・来歴(プロベナンス)の保証度合いをレベル化する枠組み。

 **サプライチェーン完全性****推移的依存 Transitive Dependency**

直接依存が更に依存する間接的な依存。脆弱性の影響評価では直接依存だけでなく推移的依存も対象とする。

 **依存関係管理**

④ 基礎概念 — 規格・フレームワーク／規制マトリクス

「用語規格／部品表／完全性FW／法令」を混同しない

CONCEPT

名称	種別	要点（試験での問われ方）
JIS Q 27000	用語規格(ISMS)	リスク特定/分析/評価/対応、残留リスク等の定義を規定。 Q1・Q2の根拠。
JIS Q 27001	ISMS要求事項	ISMS構築・運用・認証の要求事項。PDCAでリスクを継続管理。
個人情報保護法	国内法(2022全面施行)	漏えい等報告・本人通知の義務化、要配慮個人情報、仮名加工情報。 Q3の根拠。
SPDX / CycloneDX	SBOM標準フォーマット	SPDX=ISO/IEC 5962・ライセンス管理、CycloneDX=OWASP・脆弱性用途。 Q4。
SLSA	完全性フレームワーク	ビルド来歴の保証度合いをレベル化。改ざん耐性を段階的に要求。 Q5の正解。
NIST SSDF (SP800-218)	セキュア開発FW	開発ライフサイクル全体の実践事項。SBOM・来歴管理の上位文脈。

💡 頻出の軸: 「用語定義=JIS Q 27000」「ISMS認証=27001」「個人データの取扱い=個人情報」「部品可視化=SBOM(SPDY/CycloneDX)」「ビルド来歴保証=SLSA」。この対応の取り違えが4択のひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. 用語問題は**プロセスの位置**で切る。対応=修正、アセスメント=特定/分析/評価。
2. 残留リスクは「**対応後**に残る+オーナー承認」がセット。固有/二次リスクと区別。
3. 個情法は**要配慮=取得に事前同意/仮名加工=第三者提供原則禁止**を丸暗記。
4. SBOMは「**版数・依存を可視化し影響範囲を即特定**」が主目的。SLSAは来歴保証。

⚠ よくあるひっかけ

- 漏えい報告は「人数によらず対象になる類型(要配慮・不正目的等)」がある。1,000人超だけではない。
- SBOMを「**動的監視(EDR)**」やバイナリのハッシュのみと説明する選択肢は誤り。
- typosquattingを「**署名鍵の窃取**」と説明するのは別攻撃との混同。
- 脆弱性評価で「直接依存だけ確認、推移的依存は不要」は誤り。

合言葉: 「定義(プロセスの位置)×制度(適用範囲)×技術(SBOM・来歴)」で分類 → 対策は「**一元管理・可視化・事前同意・来歴/署名検証・推移的依存まで評価**」の語彙に集約される。

JIS Q 27000:2019(情報セキュリティマネジメントシステム-用語)における「リスク対応」の説明として、適切なものはどれか。

ア リスクの重大性を評価するために、算定されたリスクを与えられたリスク基準と比較するプロセス

イ リスクを発見、認識及び記述するプロセスであり、リスク源、事象、それらの原因及び起こり得る結果の特定を含む

ウ リスクを修正するプロセスであり、リスクの回避、低減、共有(移転)及び保有(受容)などの選択肢を含む

エ リスクの特質を理解し、リスクレベルを決定するプロセス

正解 ウ ア=リスク評価/イ=リスク特定/エ=リスク分析(いずれもリスクアセスメントの構成要素)

▲ 空 (事実)

リスク対応(risk treatment)は「リスクを修正するプロセス」と定義される。

● 雨 (解釈)

回避・除去・低減・共有(移転)・保有(受容)の選択肢を決定・実施する段階。アセスメントの後工程。

✦ 傘 (対策)

用語は「特定→分析→評価(=アセスメント)」と「対応(=修正)」を明確に分けて暗記する。

組織が受容できないと判断したリスクについて、追加の管理策を導入した後になお残るリスクを表す用語はどれか。

ア 固有リスク

イ 残留リスク

ウ 二次リスク

エ リスク選好

正解 イ ア=管理策適用前のリスク/ウ=対応策自体が生む新リスク/エ=進んで受容・追求するリスクの量・種類

▲ 空 (事実)

残留リスク(residual risk)はリスク対応後に残るリスクを指す。

● 雨 (解釈)

受容にはリスク所有者(リスクオーナー)の承認が必要。「対応後」「承認」がセットの論点。

↑ 傘 (対策)

固有(前)/残留(後)の時間軸、二次リスク(新規発生)、リスク選好(量・種類)を4語で整理する。

📁 **実務メモ:** 残留リスクの受容判断はリスクオーナーが承認する点が午後でも問われやすい。「担当者が独断で受容」は誤り。

2022年4月に全面施行された改正個人情報保護法に関する記述のうち、適切なものはどれか。

ア 一定要件を満たす漏えい等が発生した場合、個人情報保護委員会への報告及び本人への通知が原則義務化された

イ 仮名加工情報は、他情報と照合しない限り個人を識別できない情報であり、第三者への自由な提供が認められている

ウ 外国の第三者へ個人データを提供する場合、本人同意があれば移転先国の制度に関する情報提供は不要である

エ 保有個人データの開示請求において、本人は書面交付のみを請求でき、電磁的記録による提供は求められない

正解 ア イ=仮名加工情報は原則第三者提供禁止/ウ=移転先国の制度等の情報提供が必要/エ=電磁的記録での提供も指定可

空 (事実)

改正法で漏えい等報告・本人通知が法的義務化された。

雨 (解釈)

対象は要配慮情報・財産的被害のおそれ・不正目的・1,000人超。前3類型は人数によらず対象。

傘 (対策)

漏えい検知時の報告フロー整備、越境移転時の情報提供、開示方法の電磁的対応を規程化する。

ソフトウェアの構成要素を一覧化する**SBOM**に関する記述のうち、適切なものはどれか。

ア **SPDX**と**CycloneDX**はいずれも**SBOM**の標準フォーマットで、**CycloneDX**は脆弱性やサプライチェーンのセキュリティ用途に強い

ウ **SBOM**を整備しても、Log4jのような脆弱性が公表された際に影響を受ける製品を特定する用途には利用できない

イ **SBOM**は実行時のメモリ上のプロセスを動的に監視し、不審な通信をリアルタイムで検知する仕組みである

エ **SBOM**は最終成果物のバイナリのハッシュ値のみを記録し、コンポーネントの名称・版数・依存関係は対象外である

正解 ア イ=EDR等の動的監視の説明で無関係/ウ=依存を辿り影響範囲を特定できる/エ=名称・版数・依存の記録が本旨

空 (事実)

SBOMは部品表。SPDX(ISO/IEC 5962・ライセンス管理)とCycloneDX(OWASP発・脆弱性用途)が代表。

雨 (解釈)

主利点は、脆弱性公表時に推移的依存まで辿り影響範囲を迅速に特定できること。

傘 (対策)

利用OSSの名称・版数・依存関係を機械可読なSBOMで一元管理し、継続的に更新する。

実務メモ: Log4Shellのような事案で「影響製品の特定に何日もかかる」課題への直接解が**SBOM整備**。午後の空欄補充で頻出。

ソフトウェアサプライチェーンの完全性を確保する取組みに関する記述のうち、適切なものはどれか。

ア SLSAは、ビルドプロセスの改ざん耐性・来歴(プロベナンス)の保証度合いをレベルで示すフレームワークである

イ typosquattingは、正規パッケージの署名鍵を窃取して同一名で改ざん版を公開する攻撃を指す

ウ cosign(Sigstore)は、配布物への電子署名と検証を行うが、コンテナイメージには適用できない

エ OSSの依存ライブラリに脆弱性が発見された場合、直接依存だけを確認すれば推移的依存の影響は考慮不要である

正解 ア イ=typosquattingは酷似名の悪意パッケージ(鍵窃取とは別)/ウ=cosignはコンテナイメージにも署名可/エ=推移的依存も評価対象

空 (事実)

SLSA(Supply-chain Levels for Software Artifacts)はビルド由来の保証度合いをレベル化する枠組み。

雨 (解釈)

来歴情報の生成・検証やビルド環境の改ざん耐性を段階的に要求する。完全性確保の共通尺度。

傘 (対策)

来歴の生成・検証、cosign/Sigstoreによる署名検証、推移的依存を含む脆弱性評価を組み合わせる。



午後 記述式 — シナリオ要点

D社(医療機器メーカー)/OSS利用とサプライチェーンリスクの管理

記述

◆ シナリオ (春想定) ログOSSの重大脆弱性

- 設問1: 影響特定に3日を要した根本原因 = 利用OSSの名称・版数を組織で一元管理する仕組みの欠如(管理体制の観点/40字)。
- 設問2: [a] = **SBOM**。効果 = 構成部品と版数が一覧化され、脆弱性公表時に影響製品を即座に特定できる(50字)。
- 設問3: [b] = **要配慮個人情報**(健康情報)。相違 = 取得時に原則本人の事前同意が必要。

◆ 再発防止・OSS受入れ基準

- 設問4(セキュリティ) = 既知の脆弱性・CVEの有無と対応状況を確認(30字)。
- 設問4(保守性) = 開発が継続され保守・更新が提供されているかを確認(30字)。
- 別解 = ライセンス適合性/配布元の署名・ハッシュによる真正性確認/コミュニティの活発さ。
- 全体 = 依存関係を継続管理するツール導入+リスクアセスメント再実施(供給網型攻撃を踏まえ)。

採点の分水嶺: ①原因は「一元管理の欠如」という組織的原因(技術力不足などの外れ不可) ②SBOMの効果を下線①(特定に3日)と対応づけ ③要配慮個人情報の通常個人情報との相違(事前同意/オプトアウト不可、共通事項は不可) ④設問4はセキュリティと保守性の異なる2観点。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でマネジメント・法規論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
リスク対応/アセスメント用語(27000)	最有力	低	プロセスの位置
残留リスク・リスクオーナー承認	高	中	対応後+承認
改正個人情報保護法(2022)	最有力	中	報告義務+要配慮
SBOM(SPDX/CycloneDX)	最有力	中	版数/依存の可視化
サプライチェーン完全性(SLSA/cosign)	高	高	来歴/署名検証

総括: この分野は午前IIの用語定義(リスク対応・残留リスク・要配慮/仮名加工)と、午後の実務シナリオ(OSS管理・SBOM整備・要配慮個人情報の取扱い)の両方で狙われる。近年最重要の**SBOM/サプライチェーン**と、必ず問われる**改正個人情報法の報告義務**を最優先で固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。